

POLÍTICA DE RESPOSTA A INCIDENTES DE SEGURANÇA

Diretrizes para detecção, contenção, resposta, recuperação e aprendizagem

Organização	Entidade
Identificador	PRI-005
Versão	1.0 — Proposta para revisão e aprovação
Classificação	Uso interno
Proprietário	Função responsável definida pela Direcção
Aprovação	Direcção / órgão competente
Data de emissão	09 de Outubro de 2026
Revisão	Anual ou após alteração relevante

Nota de controlo: Documento de referência para validação interna. A aprovação deve ser precedida da confirmação das responsabilidades, dos requisitos legais e regulamentares aplicáveis, dos canais operacionais e dos controlos efectivamente implementados.

Histórico e controlo do documento

Versão	Data	Descrição	Responsável
1.0	09/10/2026	Emissão inicial para revisão	Função responsável

1. Objectivo e âmbito

Estabelecer uma abordagem consistente para reportar, avaliar, conter, investigar, resolver e aprender com eventos e incidentes de segurança que afectem informação, sistemas, serviços, instalações ou terceiros relevantes.

2. Princípios de resposta

- Agir com rapidez, mas com decisões proporcionais ao impacto e ao risco.
- Priorizar segurança das pessoas, continuidade dos serviços críticos e protecção de informação.
- Preservar evidências e manter registo das decisões, horários, responsáveis e acções executadas.
- Limitar a divulgação de detalhes do incidente a pessoas autorizadas.
- Cumprir os requisitos legais, regulamentares, contratuais e de comunicação aplicáveis.
- Evitar acções destrutivas ou irreversíveis antes de avaliar o seu impacto, salvo quando necessárias para conter dano iminente.

3. Reporte e classificação

Todos os utilizadores e terceiros devem reportar imediatamente eventos suspeitos através dos canais internos publicados. Exemplos incluem malware, phishing com credenciais expostas, acesso indevido, fuga ou perda de dados, indisponibilidade, fraude, perda de equipamento, alteração não autorizada, abuso de privilégios e comprometimento de fornecedor.

A equipa designada deve registar o evento, determinar se constitui incidente, classificar severidade e impacto, identificar sistemas e dados afectados e definir o nível de escalonamento. A classificação deve considerar confidencialidade, integridade, disponibilidade, impacto financeiro, clientes, obrigações legais e reputação.

4. Fases de resposta

4.1. Preparação

Manter equipa e substitutos designados, contactos actualizados, ferramentas autorizadas, procedimentos, acesso a backups e planos de comunicação. A preparação deve ser testada por exercícios.

4.2. Detecção e análise

Validar alertas, estabelecer cronologia, delimitar âmbito, identificar indicadores de comprometimento e preservar registos relevantes. As hipóteses devem ser distinguidas dos factos confirmados.

4.3. Contenção

Aplicar medidas proporcionais, como isolar equipamentos, bloquear contas, revogar tokens, restringir tráfego ou suspender integrações comprometidas. Sempre que possível, avaliar previamente o impacto na continuidade dos serviços e manter registo da autorização.

4.4. Erradicação e recuperação

Remover a causa, corrigir vulnerabilidades, rodar credenciais comprometidas e restaurar serviços a partir de fontes confiáveis. A recuperação deve incluir verificações de integridade, monitorização reforçada e validação do proprietário do serviço.

4.5. Encerramento e lições aprendidas

Documentar causa provável ou confirmada, impacto, decisões, custos conhecidos, controlos falhados e acções de melhoria. O encerramento exige responsável, evidências e acompanhamento das acções correctivas.

5. Crises e escalonamento

Incidentes com impacto elevado, suspeita de fraude, dados sensíveis, sistemas críticos, indisponibilidade prolongada ou potencial obrigação de reporte devem ser escalados imediatamente para a gestão e para as funções de Segurança da Informação, TI, Jurídico/Compliance, risco e comunicação, conforme o caso.

A gestão de crise deve definir um responsável pela coordenação, prioridades de negócio, autoridade para decisões urgentes e frequência dos pontos de situação. As comunicações externas devem ser centralizadas e aprovadas pelas funções competentes.

6. Evidências e comunicação a autoridades

- Preservar registos, imagens forenses, mensagens, indicadores e outros elementos relevantes com controlo de acesso e cadeia de custódia documentada quando necessário.
- Não alterar nem eliminar evidências relevantes; limitar a recolha ao necessário e autorizado.
- Avaliar prontamente se existem deveres de notificação a autoridades, reguladores, titulares de dados, clientes ou parceiros.
- Os prazos e canais de reporte devem ser confirmados a partir dos requisitos legais e regulamentares vigentes; esta política não substitui a análise jurídica do incidente.

7. Exercícios e melhoria

A capacidade de resposta deve ser testada periodicamente por exercícios de mesa, simulações técnicas ou outros testes proporcionais ao risco. As conclusões devem resultar em acções com responsáveis e prazos. Incidentes reais e exercícios devem contribuir para melhorar controlos, formação, continuidade e procedimentos.

Responsabilidades principais

Papel	Responsabilidades
Direcção / gestor de crise	Tomar decisões de negócio, disponibilizar recursos e aprovar comunicações e medidas dentro da sua autoridade.
Coordenador de resposta	Gerir o incidente, manter cronologia, atribuir tarefas, coordenar escalonamento e documentar decisões.
TI / Operações	Executar contenção técnica, investigação, erradicação e recuperação.
Segurança da Informação	Classificar riscos, orientar resposta, preservar evidências e acompanhar melhorias.
Jurídico / Compliance / Privacidade	Avaliar obrigações de notificação, contratos, privacidade e comunicações regulatórias.
Todos os utilizadores	Reportar eventos de imediato e cooperar com as instruções autorizadas.

Monitorização e evidências

A função responsável deve definir a periodicidade, fonte, responsável e destinatário de reporte dos indicadores abaixo, mantendo evidências proporcionais ao risco e aos requisitos aplicáveis.

- Tempo entre detecção, reporte, triagem e contenção.
- Percentagem de incidentes com classificação e cronologia completas.
- Número de incidentes recorrentes e acções correctivas vencidas.
- Percentagem de exercícios realizados conforme o plano.
- Percentagem de contactos e procedimentos revistos no período.

Excepções, incumprimento e revisão

Qualquer excepção deve ser solicitada por escrito, justificada, avaliada quanto ao risco, aprovada pela autoridade competente, limitada no tempo e acompanhada de medidas compensatórias. Não pode contrariar obrigações legais ou regulamentares. O incumprimento pode resultar em medidas correctivas, restrição de acessos ou consequências disciplinares e contratuais, conduzidas pelas áreas competentes. O documento deve ser revisto pelo menos anualmente e após alterações relevantes, incidentes significativos ou mudanças legais.

Aprovação formal

Etapa	Responsável / nome	Assinatura e data
Elaboração	A preencher	A preencher
Revisão técnica / jurídica	A preencher	A preencher
Aprovação — Direcção competente	A preencher	A preencher

Entrada em vigor: após aprovação formal e divulgação aos destinatários abrangidos.